

Capítulo 8: Seguridad

▼ Propiedades de la Comunicación Segura

Para que una comunicación se considere segura en la red, debe garantizar cuatro propiedades fundamentales:

- **Confidencialidad:** Solo el emisor y el receptor deben comprender el contenido del mensaje, lo que hace indispensable el uso de algoritmos de cifrado.
- **Integridad de los mensajes:** Garantizar que el contenido no sea alterado (maliciosa o accidentalmente) durante su transmisión.
- **Autenticación del punto terminal:** Ambas partes deben poder confirmar y verificar la identidad real del otro.
- **Seguridad operacional:** Proteger las redes de las organizaciones (por ejemplo, frente a ataques DoS o gusanos) mediante dispositivos como firewalls y sistemas de detección de intrusiones.

▼ Principios de Criptografía

La criptografía es la base para lograr la confidencialidad. Existen dos enfoques principales:

- **Criptografía de clave simétrica:** El emisor y el receptor comparten una única clave secreta idéntica.
- **Criptografía de clave pública/privada:** Resuelve el problema de distribuir una clave secreta previa. Cada entidad tiene un par de claves: una **clave pública** (conocida por todos) y una **clave privada** (secreta). El algoritmo **RSA** es el más utilizado; sin embargo, debido a que requiere mucho tiempo de procesamiento computacional, en la práctica se usa en combinación con la clave simétrica: se utiliza la clave pública para transferir de manera segura una "clave de sesión" (simétrica), y luego el mensaje se cifra rápidamente con esa clave de sesión.

▼ Integridad, Autenticación y Certificados

- Para lograr la integridad, se utilizan **funciones hash criptográficas** (como MD5 o SHA-1), que toman un mensaje y calculan una "huella digital" de tamaño fijo.
- Un **Código de Autenticación de Mensajes** verifica la integridad concatenando una clave secreta compartida al mensaje antes de aplicar el hash, sin necesidad de usar algoritmos de cifrados complejos.
- Las **firmas digitales** actúan como una firma humana: el emisor calcula el hash del mensaje y lo cifra con su propia *clave privada*. Alguien que recibe el mensaje puede verificarlo con la clave pública del emisor; como nadie más tiene la clave privada, la firma es infalsificable.
- Para evitar que un atacante entregue una clave pública falsa, intervienen las **Autoridades de Certificación**. Estas entidades validan identidades y emiten **certificados** que asocian y firman digitalmente la clave pública de una persona, router o servidor web.
- En la autenticación directa entre servidores o clientes, es vital prevenir los **ataques de reproducción o playback** (cuando un atacante graba y reenvía una contraseña cifrada antigua). La solución es los **nonces**, números aleatorios generados en el momento y que "se usan una sola vez en la vida", demostrando que el emisor está transmitiendo en vivo.

▼ Seguridad aplicada en Capas de Protocolos

- **Capa de Aplicación (Correo Seguro):** El software **PGP (Pretty Good Privacy)** proporciona confidencialidad, autenticación del emisor e integridad en correos electrónicos, combinando claves de sesión, criptografía de clave pública y firmas digitales.
- **Capa de Transporte (SSL / TLS):** Mejora las conexiones TCP dotándolas de seguridad, algo crucial para el comercio electrónico. TLS incluye tres fases: acuerdo o *handshake* (para negociar algoritmos e intercambiar certificados y nonces), deducción de claves maestras, y transferencia de datos cifrados con códigos HMAC y números de secuencia (para evitar interceptaciones y reordenamiento de paquetes).

- **Capa de Red (IPsec y VPNs):** Proporciona "cobertura general" u host-a-host cifrando las cargas útiles de todos los datagramas. El protocolo ESP de IPsec opera estableciendo **Asociaciones de Seguridad (SA)**. IPsec se utiliza extensamente en "modo túnel" para la creación de **Redes Privadas Virtuales (VPN)** de las corporaciones a través del Internet público.
- **Capa de Enlace (Redes Inalámbricas):** Dada la vulnerabilidad del aire como medio, el estándar **WPA2** reemplazó al frágil protocolo WEP original. Incorpora un servidor de autenticación dedicado, métodos estrictos de autenticación mutua (EAP) y algoritmos robustos (como AES) para cifrar tramas wifi. Las redes celulares 4G/5G aplican conceptos similares para autenticación entre dispositivos móviles y la red local/visitada.

▼ Seguridad Operacional (Defensas perimetrales)

Para frenar ataques hacia la red de una institución, se colocan dispositivos en la frontera con Internet:

- **Cortafuegos (Firewalls):** Aíslan la red interna analizando y bloqueando tráfico. Los *filtros de paquetes tradicionales* toman decisiones paquete a paquete (revisando direcciones IP, puertos y bits de TCP/UDP/ICMP). Los *filtros con memoria de estado* van más allá y mantienen una "tabla de conexiones" rastreando todos los handshakes de TCP para frenar paquetes mal formados o que no pertenecen a ninguna sesión activa. Las *pasarelas de aplicación* miran la propia carga útil a nivel de aplicación (ej. en Telnet) para pedir autorización y contraseñas.
- **Sistemas de Detección y Prevención de Intrusiones (IDS/IPS):** A diferencia de un firewall ordinario, estos dispositivos realizan una "inspección profunda" en la carga útil de los paquetes buscando firmas que coincidan con miles de ataques conocidos (troyanos, mapeo de puertos, pings de nmap) o identifican anomalías estadísticas en el tráfico. Un sistema gratuito muy utilizado de este tipo es **Snort**.